

Cibersegurança — Módulo 1 — Trabalho prático (parte I)

O intercâmbio de chaves Diffie-Hellman

‘Never invent a cryptography system yourself’
“Never implement a cryptography system yourself”

A primeira parte da avaliação prática do Módulo I - Mecanismos para proteção da informação, da U.C. de CiberSegurança, pode ser realizado individualmente ou em grupos de até 3 membros e consiste, primeiramente, na implementação dos algoritmos descritos (a realizar em casa) e, posteriormente, na utilização das implementações em **exercícios em sala de aula**:

- pelas 18h30, do dia 21 de setembro, para os alunos da turma TN;
- pelas 14h00 do dia 25 de setembro, para os alunos da TD.

As implementações utilizadas na resolução dos exercícios deverão ser entregues no Moodle no final da aula correspondente, por um dos membros do grupo, **identificando claramente** no *script*, os **NOMES DE TODOS OS MEMBROS** do grupo.

Diffie-Hellman com aperto de mãos autenticado (protocolo do tipo *Station-to-Station*)

O intercâmbio de chave de Diffie-Hellman com aperto de mãos é uma versão simples do STS, *Station-to-Station Protocol*, proposto por Whitfield Diffie, Paul van Oorschot e Michael Wiener em 1992, que combina o uso de chaves públicas de identidade de larga duração com chaves efémeras, de modo a autenticar os participantes e garantir *forward secrecy*.

O protocolo STS assume que existe uma entidade de confiança que pode autenticar as entidades participantes, Alice e Bob. Mais precisamente, há uma entidade de confiança que certifica que as chaves públicas de identidade de Alice e Bob, para um protocolo de assinatura pré-determinado, são respetivamente IK_A^{pub} e IK_B^{pub} . Por outras palavras, assume-se que só Alice e Bob estão na posse das chaves de identidade privadas correspondentes, IK_A^{pri} e IK_B^{pri} .

↪ Na implementação a realizar, as **chaves de identidade estarão associadas a um protocolo de assinatura RSA simples** (assinatura RSA simples, slides 02, página 38), ou seja:

$$(IK_A^{pub}, IK_A^{pri}) = ((n_A, e_A), (n_A, d_A)) \quad \text{e} \quad (IK_B^{pub}, IK_B^{pri}) = ((n_B, e_B), (n_B, d_B))$$

Será necessário assinar mensagens do tipo $(m_1, m_2, \dots, m_k)$ com m_i inteiros, o qual será feito utilizando a soma $(m_1 + \dots + m_k) \bmod n$, com n o módulo de quem realiza a assinatura (ver exemplo).

↪ A notação $DH(\mathbf{EK}_A, \mathbf{EK}_B)$ representa o cálculo da chave secreta partilhada por Alice e Bob num **intercâmbio Diffie-Hellman simples** com parâmetros pré-determinados p, α (intercâmbio DH, slides 02, página 14). Ou seja, se as chaves para DH de Alice e Bob são, respetivamente

$$\mathbf{EK}_A = (EK_A^{pri}, EK_A^{pub}) = (x_A, \alpha^{x_A} \bmod p) \quad \text{e} \quad \mathbf{EK}_B = (EK_B^{pri}, EK_B^{pub}) = (x_B, \alpha^{x_B} \bmod p),$$

então $K = DH(\mathbf{EK}_A, \mathbf{EK}_B)$ pode calcular-se usando a informação privada de um e a informação pública do outro, mais precisamente

$$K = (\alpha^{x_A})^{x_B} \bmod p \quad \text{ou} \quad K = (\alpha^{x_B})^{x_A} \bmod p$$

PROTOCOLO

1. Alice e Bob estão identificados através de uma entidade de confiança por chaves públicas de identidade de longa duração IK_A^{pub} e IK_B^{pub} , respetivamente.
2. Alice e Bob geram chaves efêmeras de sessão $\mathbf{EK}_A, \mathbf{EK}_B$ de tipo Diffie-Hellman num domínio estabelecido com parâmetros p e α . Isto é, Alice gera um par $\mathbf{EK}_A = (EK_A^{pub}, EK_A^{pri})$, com

$$EK_A^{pri} = x_A \quad \text{e} \quad EK_A^{pub} = \alpha^{x_A} \bmod p,$$

e Bob realiza um processo análogo.

3. Alice envia a Bob a chave efêmera pública EK_A^{pub} ;
4. Bob envia a Alice $(EK_B^{pub}, \text{sig}_{IK_B}(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub}))$;
5. Alice verifica a assinatura e responde a Bob enviando $\text{sig}_{IK_A}(EK_A^{pub}, EK_B^{pub})$. Bob verifica a assinatura da Alice (*hand-shake*)
6. Alice e Bob cifram a suas comunicações com a chave secreta partilhada $K = DH(\mathbf{EK}_A, \mathbf{EK}_B)$.

Implementações Implemente, de preferência em Python3:

- Uma função `assina_RSA(chave_privada, lista_inteiros) -> sign` com as seguintes especificações:
 - `chave_privada`: uma chave privada (n, d) para uma assinatura RSA;
 - `lista_inteiros`: uma lista de comprimento variável com números inteiros $(m_1, \dots, m_k)$;
 - `sign`: o inteiro obtido ao assinar $m = (m_1 + \dots + m_k) \bmod n$ usando RSA com chave privada (n, d) .
- Uma função `verifica_RSA(chave_publica, sign, lista_inteiros) -> True/False` com as seguintes especificações:
 - `chave_publica`: uma chave publica (n, e) para uma assinatura RSA;
 - `sign`: um inteiro;
 - `lista_inteiros`: uma lista de comprimento variável com números inteiros $(m_1, \dots, m_k)$;
 - `retorno`: True/False se assinatura é válida/inválida, isto é se `sign` é assinatura válida/inválida de $m = (m_1 + \dots + m_k) \bmod n$, calculada com a chave privada correspondente à chave pública indicada.
- Uma função `chave_DH(p, alpha) -> (x, beta)` com as seguintes especificações:
 - `p`: um primo, `alpha`: um gerador multiplicativo módulo p ;
 - `(x, beta)`: um par chave privada, chave pública para Diffie-Hellman com parâmetros p e `alpha`, ou seja $1 < x < p-1$ aleatório e $\beta = \alpha^x \bmod p$.

NOTA: Qualquer outra função implementada para resolver as questões deve estar corretamente comentada no código.

EXEMPLO: Intercâmbio de chaves de Diffie-Hellman autenticado com aperto de mãos

1. Alice e Bob estão identificados através de uma entidade de confiança por chaves públicas de identidade de longa duração IK_A^{pub} e IK_B^{pub} , respectivamente, com assinaturas de tipo RSA.

Suponha-se que as chaves públicas de Alice e Bob são, respectivamente:

$$IK_A^{pub} = (143, 7) \quad \text{e} \quad IK_B^{pub} = (119, 5)$$

Ou seja, são realmente Alice e Bob, e apenas eles, quem está na posse das chaves privadas de identidade correspondentes:

$$IK_A^{pri} = (143, 103) \quad \text{e} \quad IK_B^{pri} = (119, 77)$$

De referir que cada chave privada (n, d) e chave pública correspondente (n, e) devem ter sido calculadas de modo a verificar $ed = 1 \bmod \phi(n)$, para assegurar $x^{de} = x \bmod n$

2. Suponha-se que Alice e Bob vão realizar um intercâmbio de chaves Diffie-Hellman usando os parâmetros de domínio

$$p = 23, \alpha = 7$$

Os parâmetros de domínio, assim como a entidade de confiança que certifica as identidades, o tipo de assinatura que será usada ...etc... deve ser do conhecimento prévio da Alice e de Bob

Alice e Bob geram então chaves efêmeras de sessão EK_A , EK_B de tipo Diffie-Hellman nesse domínio:

- (a) Alice escolhe aleatoriamente $1 < x_A < p - 1$ e calcula $\alpha^{x_A} \bmod p$, que são a chave privada e a chave pública efêmera de A, respectivamente. Por exemplo, se $x_A = 14$, então:

$$EK_A^{pri} = 14 \quad \text{e} \quad EK_A^{pub} = 7^{14} \bmod 23 = 2$$

- (b) Bob escolhe aleatoriamente $1 < x_B < p - 1$ e calcula $\alpha^{x_B} \bmod p$, que são a chave privada e a chave pública efêmera de B, respectivamente. Por exemplo, se $x_B = 16$, então:

$$EK_B^{pri} = 16 \quad \text{e} \quad EK_B^{pub} = 7^{16} \bmod 23 = 6$$

3. Alice envia então a Bob a chave efêmera pública $EK_A^{pub} = 2$;
4. Bob assina a mensagem:

$$(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub}) = (143, 7, 119, 5, 2, 6)$$

usando RSA com a sua chave de identidade privada. Como indicado na descrição do protocolo, para assinar uma sequência de inteiros num RSA com módulo n_B , realiza-se primeiro adição módulo $n_B = 119$:

$$(143 + 7 + 119 + 5 + 2 + 6) \bmod 119 = 44$$

Depois, aplica-se a $h = 44$ o processo RSA com o expoente privado de Bob, d_B , (Bob está a assinar):

$$44^{77} \bmod 119 = 11$$

Bob envia a Alice

$$(EK_B^{pub}, \text{sig}_{IK_B}(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub})) = (6, 11)$$

5. Alice recebeu a $(6, 11)$ e verifica a assinatura de Bob.

No caso da assinatura RSA simples estabelecida, a verificação consiste em usar o expoente público e verificar que o resultado obtido coincide com a mensagem enviada.

- Alice sabe que a mensagem que Bob assinou é

$$(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub}) = (143, 7, 119, 5, 2, 6)$$

Alice calcula então:

$$(143 + 7 + 119 + 5 + 2 + 6) \bmod 119 = 44$$

Por outro lado, se aplica o procedimento RSA com a chave pública de Bob à assinatura que Bob enviou:

$$11^5 \bmod 119 = 44$$

Como as mensagens coincidem, a assinatura é válida.

Note-se que Alice estão em posseção de toda a informação necessária. Na descrição do protocolo foi dito que é assinada a adição das chaves públicas.

- Alice responde a Bob enviando $\text{sig}_{IK_A}(EK_A^{pub}, EK_B^{pub})$.

Ou seja, a partir de

$$(EK_A^{pub}, EK_B^{pub}) = (2, 6)$$

Alice calcula $(2 + 6) \bmod 143 = 8$ e depois assina com RSA

$$\text{sig}_{IK_A}(EK_A^{pub}, EK_B^{pub}) = 8^{103} \bmod 143 = 83$$

Alice assina usando a SUA chave privada RSA, com o seu módulo ...

- Bob verifica a assinatura recebida da Alice (*hand-shake*):

Bob sabe que a mensagem assinada foi $(2, 6)$, ou seja $2 + 6 \bmod 143 = 8$.

Por outro lado, usando o expoente público da Alice na assinatura RSA, calcula:

$$83^7 \bmod 143 = 8$$

Como coincide com a mensagem assinada, a assinatura é válida.

Bob deve verificar a assinatura usando a chave pública de Alice, com módulo da chave pública de Alice...

6. Alice e Bob cifram a suas comunicações com a chave secreta partilhada $K = DH(EK_A, EK_B)$.

- Alice calcula:

$$K = 6^{14} \bmod 23 = 9$$

- Bob calcula:

$$K = 2^{16} \bmod 23 = 9$$

A chave secreta partilhada é efetivamente 9.

Número	Aluno	Assinatura

Implementações [6 valores]: Devem incluir, pelo menos, os testes com as questões do exercício modelo 1. Valoriza-se a clareza e documentação do código.

Exercício 1 [10 valores] Suponha que Alice e Bob estão identificados através de uma entidade de confiança pelas chaves públicas de identidade de longa duração:

$$IK_A^{pub} = (143, 73) \quad e \quad IK_B^{pub} = (437, 17)$$

respetivamente (chaves públicas para uma assinatura RSA), com chaves privadas associadas $IK_A^{pri} = (143, 97)$ e $IK_B^{pri} = (437, 233)$, e que os parâmetros de domínio para o intercâmbio de chaves Diffie-Hellman são:

$$p = 997, \alpha = 814$$

1. Calcule uma chave efêmera de sessão de tipo Diffie-Hellman para Alice:

$$(EK_A^{pub}, EK_A^{pri}) =$$

2. Alice envia a Bob a chave efêmera pública EK_A^{pub} calculada em (1). Suponha que Bob obtenha a chave efêmera pública $EK_B^{pub} = 821$

Calcule a informação

$$(EK_B^{pub}, \text{sig}_{IK_B}(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub})) =$$

que Bob envia a Alice.

3. Se a assinatura de Bob for válida, calcule a informação

$$\text{sig}_{IK_A}(EK_A^{pub}, EK_B^{pub}) =$$

que Alice envia a Bob.

4. Calcule a chave secreta partilhada que Alice e Bob obtêm:

$$K = DH(EK_A, EK_B) = .$$

Exercício 2 [4 valores] Análogo ao anterior mas com problemas em algum dado: objetivo, encontrar o(s) problema(s).

Exercício 1 [10 valores] Suponha que Alice e Bob estão identificados através de uma entidade de confiança pelas chaves públicas de identidade de longa duração:

$$IK_A^{pub} = (143, 73) \quad e \quad IK_B^{pub} = (437, 17)$$

respetivamente (chaves públicas para uma assinatura RSA), com chaves privadas associadas $IK_A^{pri} = (143, 97)$ e $IK_B^{pri} = (437, 233)$, e com parâmetros de domínio para o intercâmbio de chaves Diffie-Hellman são:

$$p = 997, \alpha = 814$$

1. Calcule uma chave efêmera de sessão de tipo Diffie-Hellman para Alice:

Uma chave efêmera de tipo Diffie-Hellman para Alice pode ser:

$$(EK_A^{pri}, EK_A^{pub}) = (64, 915)$$

↪ Usar a função `chave_DH(p, alpha)` que escolhe aleatoriamente $1 < x_A < 997$ e calcula a informação pública $\alpha^{x_A} \bmod p$. Neste caso, foi escolhido $x_A = 64$. OUTRAS possibilidades de chaves efêmeras são válidas!!!

2. Alice envia a Bob a chave efêmera pública EK_A^{pub} calculada em (1). Suponha que Bob obtenha a chave efêmera pública $EK_B^{pub} = 821$

Calcule a informação

$$(EK_B^{pub}, \text{sig}_{IK_B}(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub}))$$

que Bob envia a Alice.

Tem-se que $(EK_B^{pub}, \text{sig}_{IK_B}(IK_A^{pub}, IK_B^{pub}, EK_A^{pub}, EK_B^{pub})) = (821, 103)$.

↪ Usar a função `assina_RSA(chave_privada, lista_inteiros)` com os dados `chave_privada=(437,233)` (chave privada do Bob!) e `lista_inteiros= (143, 73, 437, 17, 915, 821)` para obter a assinatura 103.

3. Se a assinatura de Bob for válida, calcule a informação $\text{sig}_{IK_A}(EK_A^{pub}, EK_B^{pub})$ que Alice envia a Bob.

A assinatura é válida.

↪ A função `verifica_RSA(chave_publica, sign, lista_inteiros)` com os dados `chave_publica=(437,17)` (chave pública do Bob), `sign=103` e `lista_inteiros= (143, 73, 437, 17, 915, 821)` retorna True

O valor pedido é

$$\text{sig}_{IK_A}(EK_A^{pub}, EK_B^{pub}) = 59$$

↪ O valor obtém-se com a função `assina_RSA(chave_privada, lista_inteiros)` com os dados `chave_privada=(143,97)` (chave privada da Alice) e `lista_inteiros= (915,821)`

4. Calcule a chave secreta partilhada que Alice e Bob obtêm, $K = DH(\mathbf{EK}_A, \mathbf{EK}_B)$.

As informações do enunciado permitem calcular a chave secreta partilhada a partir da chave efêmera privada da Alice e da chave efêmera pública do Bob

$$K = 821^{64} \bmod 997 = 434$$